Public API saturated for 47 minutes: suspected attack, confirmed partner retry loop

INC-5563 · SEV-1 · E. Baumann (SecOps) and T. Iversen (API Platform) · 2026-07-21

Jira issue	INC-5563 · actions API-2240 to API-2244
Severity	SEV-1 (critical)
Window	2026-07-14 09:02 – 09:49 CEST
Resolved	2026-07-14 09:49 CEST
Affected systems	public-api-gateway, auth-token-service
Security impact	None. No credential compromise, no data access.

1. Description

From 09:02 CEST on 14 July 2026 the public API gateway was saturated at roughly 38,000 requests per second against a normal peak of 4,500. 61% of requests from all other API clients failed with 503 or timed out. Because the traffic spike was sudden and an order of magnitude above normal, the incident was opened as a suspected DDoS and SecOps took command.

2. Impact

- 47 minutes of severe degradation for every API client.
- CHF 23,400 in SLA credits owed to 14 merchants under the API agreement.
- No data exposure; every request in the spike failed authentication.

3. Hypotheses considered

Hypothesis	Evidence	Outcome
Volumetric DDoS against the public API	WAF logs: 97% of the spike carried one partner's client id and came from that partner's registered egress range; no botnet signature; no spread across source networks.	**Ruled out at 09:24.**
Credential-stuffing attack	All requests presented the same client id with a single expired access token; no variation in credentials.	**Ruled out at 09:24.**
Partner client malfunction	Partner Kestrel Travel confirmed a deploy of their booking backend at 08:40 and reproduced the loop in their staging environment.	**Confirmed at 09:41.**

4. Root cause

Kestrel Travel's new booking backend retried every HTTP 401 immediately, without backoff and without refreshing its access token, across 1,200 worker threads. When the token expired at 09:00 every worker entered a tight retry loop. On our side, the gateway applied per-client rate limits only *after* successful authentication, so requests that failed authentication were never counted against the partner's quota and nothing throttled the loop. Either fault alone would have been contained: the partner's bug would have been rate-limited, and our ordering would not have mattered without a client retrying at that volume.

5. Timeline (CEST, 2026-07-14)

Time	Event
08:40	Kestrel Travel deploys booking backend 5.0.
09:00	Kestrel's access token expires.
09:02	Gateway request rate passes 30,000/s. API-5XX alert pages.
09:06	SEV-1 declared as suspected DDoS; E. Baumann takes command.
09:24	WAF analysis rules out DDoS and credential stuffing.
09:31	Kestrel's client id blocked at the edge. Gateway recovers partially.
09:41	Kestrel confirms the retry loop and rolls back.
09:49	Block lifted with a temporary 200 req/s cap. Resolved.

Time	Event
07-21	Joint review with Kestrel Travel attending.

6. Action plan

Jira	Action	Owner	Due	Status
API-2240	Count failed-authentication requests against the presenting client id's rate limit, before authentication completes.	T. Iversen	2026-07-31	Done
API-2241	Per-client circuit breaker: 1,000 consecutive 401s blocks the client id for 5 minutes.	T. Iversen	2026-08-07	Done
API-2242	Publish retry and token-refresh requirements in the partner API terms; require backoff on 401 and 429.	L. Reber	2026-08-14	Done
API-2243	Runbook: distinguish a single-client flood from a DDoS within 5 minutes using WAF client-id breakdown.	E. Baumann	2026-07-28	Done
API-2244	Partner onboarding load test that includes token expiry.	T. Iversen	2026-08-21	Done